



Sistema de Autenticación y Autorización

M6_AE4_ABPRO – Grupo 3 – Seguridad / con Spring Boot, JPA y MySQL
Bootcamp Full Stack Java

Integrantes Grupo 3:

Alfredo San Martín

Claudio Lira

Daniela González Campos

José Correa Herrera

Pablo varas Salamanca

Objetivo del Proyecto

Diseñar e implementar un sistema robusto que **autentique y autorice usuarios** desde una base de datos relacional, aplicando control de acceso basado en roles y garantizando seguridad integral en cada capa de la aplicación.

El sistema protege recursos sensibles mediante encriptación avanzada, validación de sesiones y prevención de ataques comunes en aplicaciones web modernas.



Autenticación por formulario

Login seguro en /login



Encriptación BCrypt

Contraseñas cifradas



Control de roles

USER y ADMIN



Protección CSRF

Tokens activos



Arquitectura del Sistema

El sistema está construido sobre **Spring Boot (MVC)** y **Spring Security**, siguiendo el patrón de arquitectura en capas. Cada componente tiene responsabilidades claramente definidas, garantizando separación de responsabilidades y facilitando el mantenimiento.



Modelo de Datos

La base de datos está diseñada con una tabla **usuarios** que almacena toda la información de autenticación. Las contraseñas nunca se guardan en texto plano, sino cifradas mediante el algoritmo BCrypt con salt automático.

Campo	Tipo	Descripción
username	VARCHAR(50)	Identificador único del usuario
password	VARCHAR(100)	Contraseña cifrada con BCrypt
role	VARCHAR(20)	Rol asignado: USER o ADMIN
enabled	BOOLEAN	Estado activo de la cuenta



Seguridad en la persistencia

El esquema implementa validación a nivel de base de datos con constraints de unicidad en username y valores predeterminados seguros.

Los índices optimizan las consultas de autenticación, reduciendo el tiempo de respuesta en el proceso de login.

Flujo de Autenticación

01

Ingreso de credenciales

El usuario accede al formulario /login e introduce su username y password

03

Consulta a base de datos

Se recupera el usuario desde MySQL mediante JPA Repository

05

Creación de sesión

Si la validación es exitosa, se establece un contexto de seguridad autenticado

02

Delegación a Spring Security

El framework intercepta la petición y delega en JpaUserDetailsService personalizado

04

Validación con BCrypt

Spring Security compara el hash almacenado con la contraseña proporcionada

06

Aplicación de roles

Se cargan las autoridades (USER/ADMIN) y se controla el acceso a recursos protegidos

Interfaz de Usuario

Diseño moderno y responsivo

La interfaz está construida con **Bootstrap 5** y **Thymeleaf**, proporcionando una experiencia de usuario fluida y profesional en cualquier dispositivo.

- **Formulario de login estilizado:** validación en cliente y servidor con mensajes de error claros
- **Navbar dinámica:** se adapta automáticamente según el rol del usuario autenticado
- **Paneles diferenciados:** vistas específicas para usuarios regulares y administradores
- **Diseño accesible:** cumple con estándares WCAG para inclusividad



Retos Técnicos y Soluciones

Integración Security + JPA

Desafío: Conectar Spring Security con la capa de persistencia

Solución: Implementación de UserDetailsService personalizado que utiliza JPA Repository para cargar usuarios desde MySQL

Cifrado de contraseñas

Desafío: Almacenar credenciales de forma segura

Solución: BCryptPasswordEncoder con factor de trabajo 12, generando hashes únicos con salt automático

Control granular de roles

Desafío: Restringir acceso según privilegios

Solución: Configuración de SecurityFilterChain con expresiones hasRole('ADMIN') y authenticated()

Protección contra CSRF

Desafío: Prevenir ataques de falsificación de peticiones

Solución: Tokens CSRF habilitados por defecto, integrados automáticamente en formularios Thymeleaf

Experiencia de usuario

Desafío: Interfaces profesionales y coherentes

Solución: Bootstrap 5 + componentes Thymeleaf con fragmentos reutilizables y temas personalizados

Conclusiones



Sistema completo y funcional

Se implementó exitosamente un sistema integral de autenticación y autorización basado en roles (USER/ADMIN), cumpliendo todos los requisitos de seguridad establecidos.



Seguridad garantizada

Las credenciales están protegidas mediante **BCrypt** con salt automático, y todos los formularios incluyen protección **CSRF** activa contra ataques de falsificación.



Arquitectura sólida

La aplicación sigue correctamente el patrón **MVC** con **Spring Security** y **JPA**, garantizando mantenibilidad, escalabilidad y separación de responsabilidades.



Diseño profesional

Interfaz moderna y responsiva desarrollada con **Bootstrap 5** y **Thymeleaf**, proporcionando una experiencia de usuario intuitiva y accesible.

Este proyecto demuestra una comprensión práctica profunda de los principios de seguridad en aplicaciones web modernas.

Gracias por su atención